

Only **trusted code** runs in production

not "whatever is in the registry"

Most clusters



any image in the registry



door wide open

stolen token? injected workflow? moved tag?

it runs 🤖



This project



signed by OUR pipeline



checked at the door

6 attacks tried
in the test

all refused ✅

How bad code gets into production 📌

1 · Injected workflows



5,500 repos

in 6 hours (May 2026)

2 · Moved tags



@v1 → evil commit

CI secrets stolen

3 · Stolen registry token



push any image

same name, new content

4 · Cluster runs it



no questions asked

"it came from our registry"

THE IDEA

Treat images like **sealed medicine**



the image

+ 4 signed papers



factory seal

signed by OUR pipeline



origin certificate

which repo + commit (SLSA)



lab test

no critical vulnerabilities



ingredient list

every library (SBOM)



the pharmacist (Kyverno)

checks every seal before it's handed out

WHEN TO USE IT

Great for... / skip it when...



Kubernetes in production



regulated: NIS2, CRA, SBOM rules



many people can push images



GitOps (Argo CD, Flux) already in use

Skip it when...



a personal test cluster nobody depends on



no containers at all (plain VMs, serverless)



you can't protect the release workflow file
(it is the one thing everything trusts)

HOW A TEAM USES IT

Merge a PR. The rest is proven.

1



Merge to main

reviewed; workflows pinned & linted

2



Build · scan · sign

no keys: GitHub identity → Sigstore

3



Attack test runs

fresh cluster, 6 attacks must fail

4



GitOps deploys

only the verified digest is promoted

5

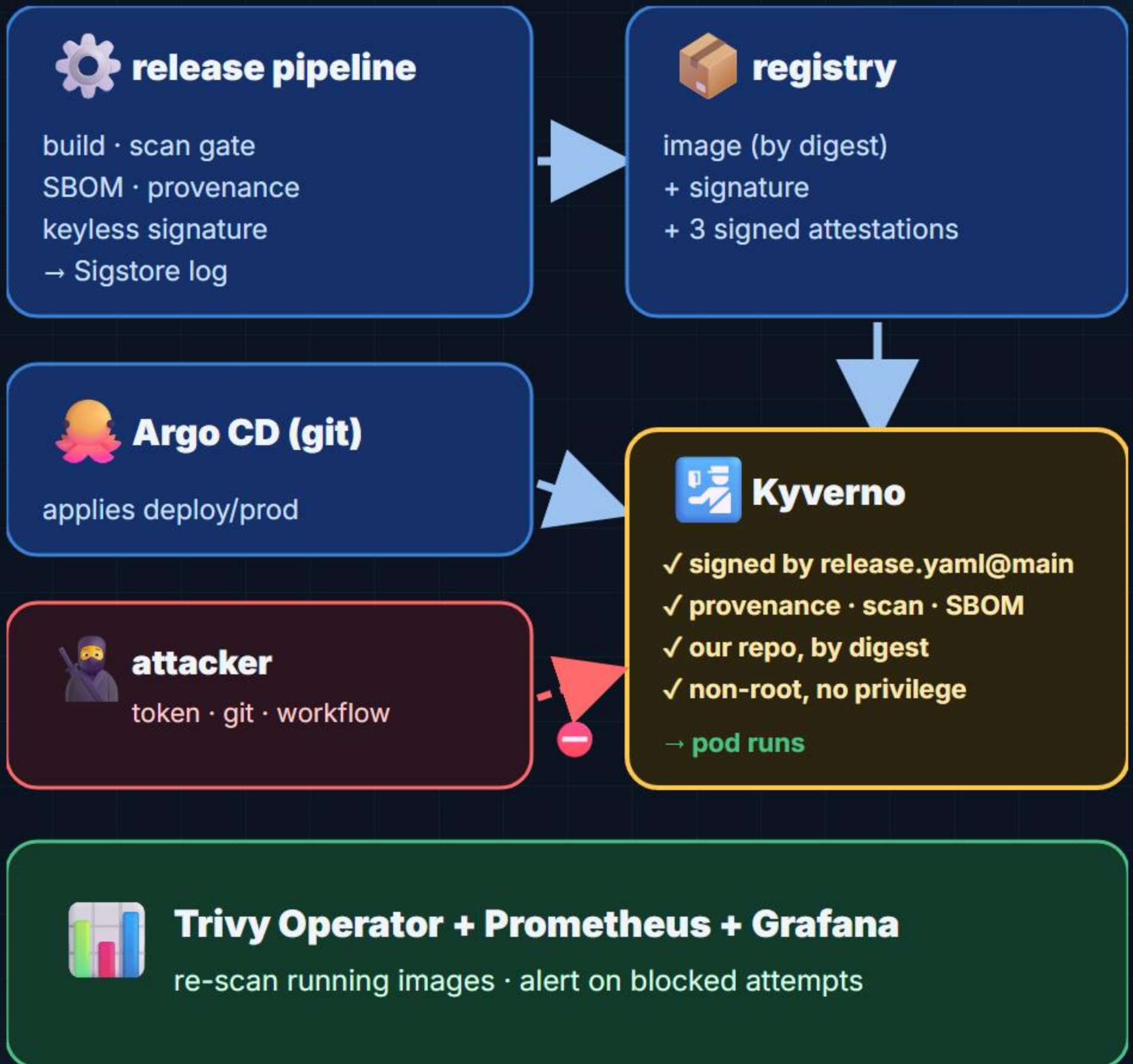


Watched while running

new CVE tomorrow? alert.

ARCHITECTURE

Proof travels with the image



HOW IT WORKS INSIDE

6 checks for every pod, in ~1 second

1 signature

certificate says: release.yaml on main (not "any workflow")

2 provenance

signed: built from this repository's main branch

3 scan

signed report: 0 CRITICAL, 0 HIGH

4 SBOM

signed list of every component

5 registry + digest

only our repo; tag rewritten to the verified digest

6 safe pod

non-root · no privilege · read-only · limits

any check fails → the pod is never created

7 attacks: 6 refused, 1 caught

 image from another registry  0.5 s

 unsigned image, stolen token  2.1 s

 tampered copy of our image  2.0 s

 **VALID** signature from an injected workflow + forged provenance  2.0 s

 our image, privileged  0.4 s

 malicious commit to git (GitOps)  6 s

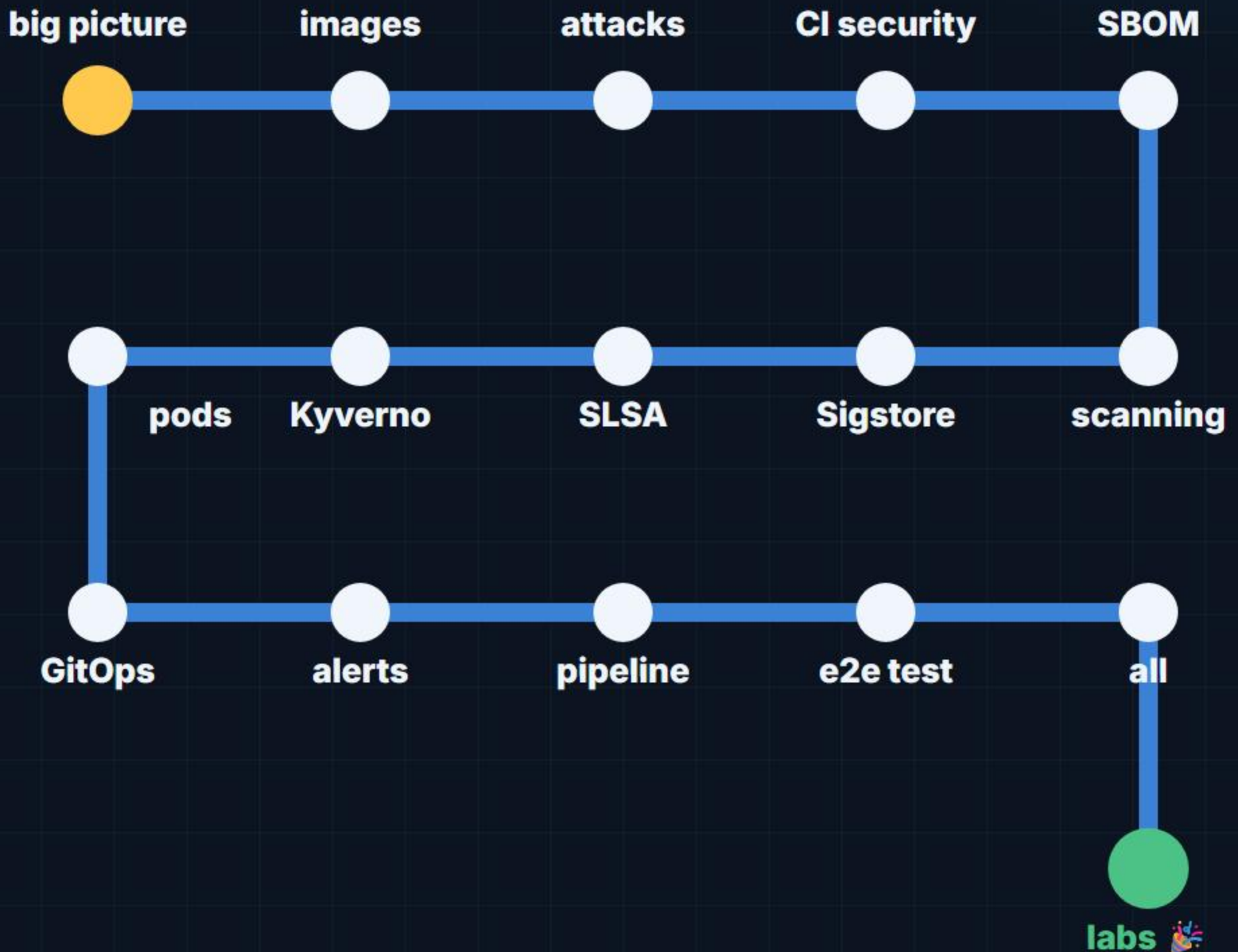
 old image with known CVEs (running)  **alert**

the real release: admitted · service never went down

times = how long the cluster took to say "no"

FREE STUDY MATERIAL

Learn every piece from zero



60

page PDF

9

hands-on labs

25

interview Q&A

TRY IT YOURSELF

Check a real signature in 1 command



```
$ scripts/platform-up.sh
```

whole platform



```
$ cosign verify ...storefront-api
```



who built it



```
$ kubectl run evil --image=...
```



refused



```
$ kubectl get policyreports
```



```
$ git push → CI attacks it
```



the image is public: anyone can verify it

YOUR TURN

**With your registry password,
could I run **my** code in your
cluster?**



Code + study guide

github.com/sufyanahmadkamboh



All my projects

sufyanahmadkamboh.github.io

Tell me honestly in the comments 🙌